



VIT[®]

Vellore Institute of Technology

(Deemed to be University under section 3 of UGC Act, 1956)

SCHOOL OF COMPUTER SCIENCE ENGINEERING AND INFORMATION (SCORE)

CSE3502- INFORMATION SECURITY MANAGEMENT

ASSESSMENT -4

NAME: AJAY KUMAAR S

REGISTER NUMBER: 22MIS0573

COURSE NAME: INFORMATION SECURITY MANAGEMENT

COURSE CODE: CSE3502

SLOT: L21+L22

Under the guidance of:

Dr. Navaneethan C

AIM:

To perform email spoofing using Email Spoofing Tool (EST), understand how spoofed emails work, and analyze the security risks associated with email spoofing.

TOOLS REQUIRED:

- Email Spoofing Tool (EST)
- SMTP Server
- Temporary Mail Service (Temp Mail)
- Internet Connection
- Web Browser

PROCEDURE:

- Open the Email Spoofing Tool (EST).
- Enter the sender email address (spoofed email address).
- Enter the receiver email address (temporary mail address).
- Enter the subject of the email.
- Type the email message content.
- Configure SMTP server and port (25 / 2525).
- Click on Send Email.
- Open the temporary mail inbox.
- Verify that the spoofed email is received.
- View the email header to analyze spoofing details.

SCREENSHOTS:

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history: no such system.  
(kali@kali)~  
$ est list  
EST - Email Spoofing Tool  
Professional Security Assessment v2.0.1  
  
Advanced Email Security Testing Framework  
For Authorized Penetration Testing Only  
Educational & Research Purposes  
  
Author: Tech Sky - SRT  
License: MIT  
  
⚠ LEGAL NOTICE: This tool is for authorized security testing only.  
Obtain explicit written permission before testing any systems.  
Unauthorized use may violate applicable laws and regulations.  
  
■ Available Email Spoofing Scenarios:  
  Business Email Compromise  
    1. CEO Fraud - Urgent Wire Transfer ●  
      From: John Smith, CEO <ceo@targetcompany.com>  
      Subject: URGENT: Wire Transfer Authorization Required  
      Description: CEO impersonation requesting urgent financial transaction
```

```
kali@kali: ~  
Session Actions Edit View Help  
  From: IT Support Team <helpdesk@targetcompany.com>  
  Subject: Action Required: Password Reset Verification  
  Description: IT support impersonation for credential harvesting  
  Financial Services Phishing  
    3. PayPal Security Alert ●  
      From: PayPal Security Team <security@paypal.com>  
      Subject: Security Alert: Unusual Account Activity Detected  
      Description: PayPal impersonation for account compromise  
  Software/License Fraud  
    4. Microsoft 365 License Expiration ●  
      From: Microsoft 365 Admin <noreply@microsoft.com>  
      Subject: ACTION REQUIRED: Your Microsoft 365 License Expires Today  
      Description: Microsoft service impersonation for credential theft  
  Financial Institution Fraud  
    5. Bank Account Verification ●  
      From: Bank of America Security <security@bankofamerica.com>  
      Subject: Immediate Verification Required - Account Suspension Notice  
      Description: Banking institution impersonation for credential harvesting  
  Total scenarios: 5  
  Use 'est test <id> <target>' to run a scenario
```

```
kali@kali: ~/EST
Session Actions Edit View Help

(kali@kali)~[~/EST]
$ est server --port 2525

EST SMTP SERVER v2.0.1
Email Spoofing Tool - Server Mode

Server Status: ACTIVE
Listening on: 0.0.0.0:2525
Log file: /home/kali/.est/est_tests.log
Statistics: 0 connections, 0 emails processed

Server Features:
• Multi-threaded connection handling
• Automatic MX record resolution
• Real-time email relay to destinations
• Comprehensive audit logging
• Professional SMTP protocol compliance

Quick Test Commands:
telnet 0.0.0.0 2525
est test 1 target@example.com

Press Ctrl+C to stop server

2026-03-25 10:42:33,265 - INFO - New SMTP connection from 127.0.0.1:38074
2026-03-25 10:42:33,267 - INFO - [127.0.0.1:38074] Spoofed sender: ceo@targetcompany.com
2026-03-25 10:42:33,268 - INFO - [127.0.0.1:38074] Target: wiked51955@jsncos.com
```

```
(kali@kali)~[~/]
$ est test 1 wiked51955@jsncos.com

EST - Email Spoofing Tool
Professional Security Assessment v2.0.1

Advanced Email Security Testing Framework
For Authorized Penetration Testing Only
Educational & Research Purposes

Author: Tech Sky - SRT
License: MIT

LEGAL NOTICE: This tool is for authorized security testing only.
Obtain explicit written permission before testing any systems.
Unauthorized use may violate applicable laws and regulations.

Executing Email Spoofing Test

Scenario: CEO Fraud - Urgent Wire Transfer
Category: Business Email Compromise
Severity: Critical
Spoofed From: John Smith, CEO <ceo@targetcompany.com>
Target: wiked51955@jsncos.com
SMTP Server: localhost:2525
Timestamp: 2026-03-25 10:42:33

Initiating SMTP connection...
Sending spoofed email...
Email spoofing test completed successfully!
Check target inbox: wiked51955@jsncos.com
2026-03-25 10:42:36,378 - INFO - Test logged: scenario_test - CEO Fraud - Urgent Wire Transfer
```

<https://www.kali.org/kali-nethunter/>



John Smith, CEO
ceo@targetcompany.com

Date:
25-03-2026 10:42:36

Subject: URGENT: Wire Transfer Authorization Required

I need you to process an urgent wire transfer for \$85,000 to our new vendor immediately. This is time-sensitive and confidential. Please handle this discreetly and confirm once completed.

Amount: \$85,000

Account details will be provided separately.

Regards,

John Smith

Chief Executive Officer

This email was sent using EST (Email Spoofing Tool) for authorized security testing purposes. If you received this email unexpectedly, please contact your IT security team immediately.

Test Details:

- Scenario: CEO Fraud - Urgent Wire Transfer

```
kali@kali: ~
Session Actions Edit View Help
└─$ est custom --from-email "ceo@targetcompany.com" \
--from-name "John Smith, CEO" \
--subject "Urgent Request" \
--body "Hello vicky How are you" \
--target "wiked51955@jsncos.com"

EST - Email Spoofing Tool
Professional Security Assessment v2.0.1

Advanced Email Security Testing Framework
For Authorized Penetration Testing Only
Educational & Research Purposes

Author: Tech Sky - SRT
License: MIT

⚠ LEGAL NOTICE: This tool is for authorized security testing only.
Obtain explicit written permission before testing any systems.
Unauthorized use may violate applicable laws and regulations.

🔴 Executing Custom Email Spoofing Test

📧 Spoofed From: John Smith, CEO <ceo@targetcompany.com>
📧 Target: wiked51955@jsncos.com
📧 Subject: Urgent Request
📧 SMTP Server: localhost:2525
📧 Timestamp: 2026-03-25 11:01:41

🔧 Initiating SMTP connection...
📧 Sending custom spoofed email...
✅ Custom email spoofing test completed successfully!
📧 Check target inbox: wiked51955@jsncos.com
2026-03-25 11:01:45,678 - INFO - Test logged: custom_test - custom
```

[<](#) **BACK TO LIST**

Delete **Source**



John Smith, CEO
ceo@targetcompany.com

Date:
25-03-2026 11:01:45

Subject: Urgent Request

Hello vicky How are you

This email was sent using EST (Email Spoofing Tool) for authorized security testing purposes. If you received this email unexpectedly, please contact your IT security team immediately.
EST v2.0.1 - Professional Email Security Assessment Framework

```
kali@kali: ~/EST
Session Actions Edit View Help
• Comprehensive audit logging
• Professional SMTP protocol compliance

🔴 Quick Test Commands:
telnet 0.0.0.0 2525
est test 1 target@example.com

🔴 Press Ctrl+C to stop server

2026-03-25 10:42:33,265 - INFO - New SMTP connection from 127.0.0.1:38074
2026-03-25 10:42:33,267 - INFO - [127.0.0.1:38074] Spoofed sender: ceo@targetcompany.com
2026-03-25 10:42:33,268 - INFO - [127.0.0.1:38074] Target: wiked51955@jsncos.com
2026-03-25 10:42:33,269 - INFO - [127.0.0.1:38074] Processing spoofed email from ceo@targetcomp
any.com to ['wiked51955@jsncos.com']
2026-03-25 10:42:33,269 - WARNING - DNS library not available, using fallbacks
2026-03-25 10:42:34,116 - INFO - Attempting relay to wiked51955@jsncos.com via 1 MX servers
2026-03-25 10:42:36,376 - INFO - ✅ Email delivered to wiked51955@jsncos.com via mail.jsncos.co
m
2026-03-25 10:42:36,377 - INFO - [127.0.0.1:38074] Connection closed
2026-03-25 11:01:41,273 - INFO - New SMTP connection from 127.0.0.1:59822
2026-03-25 11:01:41,275 - INFO - [127.0.0.1:59822] Spoofed sender: ceo@targetcompany.com
2026-03-25 11:01:41,276 - INFO - [127.0.0.1:59822] Target: wiked51955@jsncos.com
2026-03-25 11:01:41,276 - INFO - [127.0.0.1:59822] Processing spoofed email from ceo@targetcomp
any.com to ['wiked51955@jsncos.com']
2026-03-25 11:01:41,277 - WARNING - DNS library not available, using fallbacks
2026-03-25 11:01:41,705 - INFO - Attempting relay to wiked51955@jsncos.com via 1 MX servers
2026-03-25 11:01:45,676 - INFO - ✅ Email delivered to wiked51955@jsncos.com via mail.jsncos.co
m
2026-03-25 11:01:45,677 - INFO - [127.0.0.1:59822] Connection closed
```

Case Study 1 — Phishing Attack in an Organization

Q1. Explain how email spoofing could have been used in this attack

Email spoofing is a technique in which an attacker **falsifies the sender's email address** to make it appear as though the email originates from a trusted source. This is possible because the **SMTP (Simple Mail Transfer Protocol)** does not inherently verify the authenticity of the sender's address.

In this case, the attacker impersonates the IT department by modifying the **“From” field** in the email header. The employee receives an email that appears legitimate and is tricked into believing it is from the official IT team. The email contains a malicious link leading to a **fake login page**, which visually resembles the organization's actual login portal.

When the employee enters their credentials:

- The data is captured by the attacker
- The attacker uses these credentials to gain unauthorized access
- This leads to a **data breach**

Thus, email spoofing acts as the **initial attack vector**, enabling phishing by creating trust and deceiving the user.

Q2. Which EST feature could simulate this attack scenario?

An Email Spoofing Tool (EST) provides several features that can simulate such an attack:

1. Custom Header Configuration

Allows modification of email headers such as:

- From
- Reply-To
- Return-Path

2. Sender Address Spoofing

Enables attacker to impersonate legitimate domains (e.g., it-support@company.com)

3. HTML Email Crafting

Allows embedding of malicious links disguised as legitimate URLs

4. SMTP Server Configuration

Sends emails through external or open SMTP servers without authentication

5. Attachment Simulation (optional)

Can include malicious files or fake documents

These features collectively simulate a **real-world phishing attack scenario**.

Q3. What vulnerabilities allowed this attack to succeed?

The success of the attack is due to multiple vulnerabilities:

1. Lack of Email Authentication

- Absence of **SPF, DKIM, and DMARC**
- No verification of sender authenticity

2. Human Vulnerability (User Awareness)

- Employee did not verify email legitimacy
- Fell victim to social engineering

3. Absence of Multi-Factor Authentication

- Credentials alone were sufficient for access

4. Weak Email Filtering

- No phishing detection mechanisms
- Malicious link was not blocked

5. Poor URL Validation

- Fake login page was not detected

Thus, both **technical and human factors** contributed to the attack.

Q4. Suggest technical measures to prevent such attacks

Several technical measures can be implemented:

1. SPF (Sender Policy Framework)

- Defines authorized mail servers
- Prevents unauthorized sending sources

2. DKIM (DomainKeys Identified Mail)

- Adds cryptographic signature
- Ensures email integrity

3. DMARC (Domain-based Message Authentication)

- Enforces SPF and DKIM policies
- Can reject spoofed emails

4. Multi-Factor Authentication (MFA)

- Adds second layer of security
- Prevents unauthorized access even if credentials are stolen

5. Email Filtering Systems

- Detect phishing links
- Block suspicious emails

6. Secure Web Gateways

- Prevent access to malicious websites

These measures significantly reduce phishing risks.

Case Study 2 — SMTP Misconfiguration

Q5. Why does absence of SPF/DKIM enable spoofing?

SPF and DKIM are **email authentication mechanisms**:

- **SPF** verifies whether the sending server is authorized
- **DKIM** ensures the message has not been altered

Without these:

- No validation of sender identity
- Any SMTP server can send emails claiming to be from the domain
- Receivers cannot detect spoofed emails

Thus, attackers exploit this weakness to **impersonate legitimate domains** easily.

Q6. How would you verify this vulnerability using EST?

To verify the vulnerability:

1. Configure EST:
 - Set sender email as company domain
2. Use external SMTP server
3. Send test email to target inbox
4. Check:
 - If email is delivered successfully
 - If no warnings appear

If successful → system is vulnerable to spoofing.

Q7. What changes should be made to secure the mail server?

To secure the mail server:

1. Implement SPF

- Add DNS record specifying valid sending servers

2. Enable DKIM

- Configure digital signatures for outgoing emails

3. Enforce DMARC

- Set policy to reject or quarantine spoofed emails

4. Disable Open Relay

- Prevent unauthorized SMTP usage

5. Enable SMTP Authentication

- Require login credentials for sending emails

6. Monitor Email Logs

- Detect abnormal activity

These changes ensure **strong email validation and security**.

Case Study 3 — Social Engineering Attack

Q8. Identify the type of attack performed

The attack is classified as:

- **Business Email Compromise (BEC)**
- A form of **Social Engineering Attack**

It involves impersonating a high-level executive (CEO) to manipulate employees into performing sensitive actions.

Q9. How does email spoofing enhance social engineering attacks?

Email spoofing enhances social engineering by:

1. Increasing Credibility

- Email appears to come from trusted authority

2. Exploiting Trust

- Employees rely on familiar email addresses

3. Enabling Psychological Manipulation

- Authority (CEO)
- Urgency (immediate transfer)
- Fear (consequences of delay)

4. Bypassing Suspicion

- Legitimate-looking email reduces doubt

Thus, spoofing acts as a **trust amplifier** in social engineering.

Q10. What procedural controls could have prevented this incident?

Procedural (non-technical) controls include:

1. Verification Procedures

- Confirm requests via phone or in-person

2. Dual Authorization

- Require approval from multiple authorities

3. Employee Awareness Training

- Educate about phishing and spoofing

4. Financial Transaction Policies

- Define strict approval workflows

5. Incident Reporting Mechanism

- Encourage reporting suspicious emails

These controls reduce reliance on trust alone.

Case Study 4 — Temporary Mail Exploitation

Q11. Why are temporary email services used in spoofing experiments?

Temporary email services are used because:

- No registration required
- Anonymous usage
- Disposable inbox
- Useful for testing without affecting real accounts

They are ideal for **controlled security experiments**.

Q12. What limitations do temp mail services have in real-world attacks?

Limitations include:

- Short lifespan (emails deleted quickly)
- Often blocked by enterprise systems
- Lack of credibility
- Cannot sustain long-term attacks
- Limited functionality

Thus, they are mostly useful for **testing, not real attacks**.

Case Study 5 — Port Usage and Network Restrictions

Q13. Why is port 25 often blocked by ISPs?

Port 25 is blocked because:

- It is widely used for **spam transmission**
- Botnets exploit it for mass emailing
- Blocking reduces abuse and malicious traffic

Thus, ISPs restrict it to **prevent spam and cyber attacks**.

Q14. How does using port 2525 help bypass restrictions?

Port 2525 is an alternative SMTP port:

- Not commonly blocked
- Used for email submission
- Allows sending emails without restriction

Attackers use it to **bypass ISP filtering on port 25**.

Q15. What network-level defenses can detect such activity?

Network-level defenses include:

1. Firewalls

- Block unauthorized ports

2. Intrusion Detection Systems (IDS)

- Detect abnormal traffic patterns

3. Intrusion Prevention Systems (IPS)

- Block suspicious activities

4. Traffic Monitoring

- Analyze unusual email sending behavior

5. Rate Limiting

- Prevent mass email sending

6. SMTP Proxy Filtering

- Inspect email content and headers

These defenses provide **proactive detection and prevention**.